نیازمندی‌های بک‌اند — اپ کاربر / سازمانی / شرکتی

مبنا: سه سند مشتری — «توضیحات اپ کاربر» (نسخه‌ی ۱۴۰۵/۰۷/۱۶ با بندهای ۱ تا ۱۵)، «فیلد امنیت حساب در اپ کاربر. سازمانی» و «حریم خصوصی اپلیکیشن کاربران و سازمانی». همه‌ی محتوای لازمِ آن‌ها در همین سند و در کد آمده است. سمت اپ همه‌ی موارد زیر **پیاده و آماده** است و فقط منتظر این endpointها و فیلدهاست. تا وقتی endpointی وجود نداشته باشد (پاسخ 404 / 405 / 501)، بخش مربوطه در اپ «به‌زودی فعال می‌شود» نشان می‌دهد و خطا نمی‌دهد. اگر فیلد تازه‌ای در پاسخ نباشد، اپ رفتار قبلی را نگه می‌دارد. پس می‌توانید بخش‌ها را **تک‌تک** منتشر کنید. بخش‌های ۹ تا ۱۴ در نسخه‌ی ۱۴۰۵/۰۷/۲۰ این سند اضافه شده‌اند.

وضعیت بندهای سند مشتری

بند	موضوع	سمت اپ	کار بک‌اند
۱	آدرس‌های منتخب + حفظ سفارش نیمه‌کاره	✅	ندارد
۲	تامین تجهیزات یکسان در همه‌ی دسته‌ها	✅	ندارد
۳	درصد جداگانه برای هر کد معرف	✅	بخش ۲
۴	اطلاعات حساب سازمانی	✅	بخش ۳
۵	عیوب سرویس / محصول	✅	بخش ۴
۶	اطلاعات تکنسین و حذف شماره پس از پایان سفارش	✅	بخش ۵ (امنیتی)
۷	روش و کانال پرداخت	✅	بخش ۶
۸	تاریخ و ساعت ثبت در همه‌ی رسیدها	✅	ندارد
۹	کیف پول مأمور خرید (برداشت / تهاتر)	✅	**بخش ۱۳**
۱۰	«ویرایش» و «درخواست ویرایش» با نامه‌ی مهر و امضادار	✅	**بخش ۱۱**
۱۱	انتخاب جامع: فقط تامین کالا + استعلام + پیش‌پرداخت ۶۰٪	✅	**بخش ۹**
۱۲	عکس پروفایل گرد، آواتار، حذف، تمام‌صفحه	✅	**بخش ۱۲** (فقط حذف)
۱۳	جابه‌جایی ساعت و دقیقه در رسیدها	✅ رفع شد	ندارد
۱۴	چیدمان آیکون‌ها زیر «ضایعات»	✅ رفع شد	ندارد
۱۵	مشخصات تحویل در رسیدها	✅	**بخش ۱۰**
امنیت حساب	۹ بخش + مرحله‌ی دوم ورود	✅	بخش ۷ و **۱۴**

۰. قراردادهای مشترک

موضوع	قرارداد
احراز هویت	`Authorization: Bearer <token>` . endpointهای `/account/*` باید با **هر دو** نوع توکن (کاربر عادی و سازمانی/شرکتی) کار کنند.
پاکت پاسخ	`{ "success": true/false, "message": "...", "data": {...}, "error_code": "..." }`
خطای کسب‌وکاری	`success:false` + `message` فارسی + `error_code` . برای خطای اعتبارسنجی 422 با `message` فارسی. اپ همان `message` را به کاربر نشان می‌دهد.
endpoint پیاده‌نشده	404 کافی است؛ اپ آن را «به‌زودی» نشان می‌دهد.
تاریخ‌ها	ISO-8601 با منطقه‌ی زمانی، مثل `"2026-10-03T14:25:00+03:30"` . اپ خودش به شمسی تبدیل می‌کند.
مبالغ	تومان، عدد صحیح.
شناسه‌ی دستگاه	اپ برای هر نصب یک `device_id` تصادفی و ثابت می‌سازد (همانی که `POST /notifications/device-` `token` هم می‌گیرد).
جزئیات سفارش	اپ جزئیات را از `POST /orders/detail` با `{ orderId }` می‌خواند. هر جا در این سند «پاسخ جزئیات سفارش» آمده، منظور همین پاسخ است (و `GET /orders/{id}` اگر جای دیگری استفاده می‌شود).
خطای 401	فقط برای توکن نامعتبر/منقضی. 401 در اپ پیغام «نشست منقضی شده» را باز می‌کند؛ برای «کد اشتباه» و خطاهای اعتبارسنجی 422 بفرستید.

---

۱. سفارش — آدرس و پیش‌نویس (بند ۱) ✅ بدون نیاز به بک‌اند

- در مسیر سفارش سازمانی (سیستماتیک و جامع) بعد از «بازه زمانی / رزرو» مرحله‌ی **«آدرس‌های منتخب»** اضافه شد. حالا `address_id` در `POST /orders/submit` همیشه همان آدرسی است که کاربر انتخاب کرده. قرارداد قبلی تغییری نکرده است.
- سفارش نیمه‌کاره **روی خود دستگاه** به‌عنوان پیش‌نویس ذخیره می‌شود و در «سفارشات» با «ادامه / حذف» نمایش داده می‌شود.
- **اختیاری (برای بعد):** اگر خواستید پیش‌نویس بین دستگاه‌ها همگام شود، این سه endpoint کافی است: `GET/PUT/DELETE /orders/drafts/{id}` ، با بدنه‌ی `{ source, title, data(JSON آزاد), updated_at }` . فعلاً لازم نیست.

---

۲. کد معرف با درصد جداگانه (بند ۳)

اپ همین الان درصد هر کد را از پاسخ `/referral-codes/check` می‌خواند (`data.discount_percent`). **تغییری در اپ لازم نیست.** کارهای بک‌اند و پنل ادمین:

1. در پنل ادمین برای هر کد معرف (یا هر کاربرِ صاحب کد، مثل مأمور خرید شرکتی) دو مقدار جدا قابل تنظیم باشد (`commission_percent` همان درصدی است که در کیف پول مأمور خرید، بخش ۱۳، نمایش داده می‌شود):
   - `discount_percent`: تخفیفی که خریدار می‌گیرد.
   - `commission_percent`: پورسانتی که صاحب کد می‌گیرد.
2. `/referral-codes/check` و محاسبه‌ی سفارش از درصدِ **همان کد** استفاده کنند، نه یک درصد ثابت سراسری.

---

۳. اطلاعات حساب سازمانی / شرکتی / نیمه‌دولتی (بند ۴)

۳-۱. فیلدهای تازه در `GET /organization/profile`

```
{
  "status": "success",
  "data": {
    "organization_name": "...",
    "melicode": "10101234567",
    "registration_number": "123456",
    "economic_code": "411111111111",
    "verification_status": "pending",
    "verification_reason": "مدارک ناقص است",
    "...": "سایر فیلدهای فعلی بدون تغییر"
  }
}
```

فیلد	توضیح
`melicode`	**شناسه‌ی ملی سازمان/شرکت.** همان کلیدی است که فرم ثبت‌نام سازمانی امروز می‌فرستد. اگر در دیتابیس نام دیگری دارد، در پاسخ با همین نام برگردانید. اپ `organization_national_id` و `national_id` را هم می‌خواند.
`registration_number`	شماره ثبت شرکت
`economic_code`	شماره اقتصادی (اختیاری، ممکن است `null` باشد)
`verification_status`	یکی از `pending` (در حال بررسی توسط پنل مدیریت)، `approved`، `suspended` (معلق)، `deleted`، `rejected`. تا وقتی این فیلد نیاید، اپ از `profile_status` در `/organization/profile/status` استفاده می‌کند که فقط pending/approved/rejected دارد.
`verification_reason`	(اختیاری) دلیل تعلیق یا رد، برای نمایش به کاربر

۳-۲. ویرایش: `POST /organization/update-profile`

این endpoint علاوه بر فیلدهای فعلی، `melicode`، `registration_number` و `economic_code` (اختیاری، ممکن است رشته‌ی خالی بیاید) را هم بپذیرد. هم در بدنه‌ی JSON می‌آیند و هم در multipart (وقتی عکس جدید هست).

> ⚠️ **به‌روزرسانی:** قانون ویرایش عوض شده است. این سه فیلد جزو فیلدهای **قفل**‌اند و فقط پس از تأیید «درخواست ویرایش» پذیرفته می‌شوند. فیلدهای آزاد هم دیگر نیازی به تأیید ادمین ندارند. قرارداد کامل در **بخش ۱۱** است.

۳-۳. مدارک سازمان (اختیاری)

متد	مسیر	بدنه / پاسخ
GET	`/organization/documents`	`data: [{ id, title, url, status, status_label, uploaded_at }]`
POST	`/organization/documents`	multipart: `file` (PDF یا تصویر، پیشنهاد حداکثر 10MB)، `title` (اختیاری). پاسخ: همان آیتم.
DELETE	`/organization/documents/{id}`	`success:true`

`status` اختیاری است، مثلاً `pending | approved | rejected` با `status_label` فارسی. `url` باید برای کاربر قابل باز شدن باشد (لینک امضاشده یا لینکی که توکن را می‌پذیرد).

۳-۴. کاربران مجاز سازمان

متد	مسیر	بدنه / پاسخ
GET	`/organization/users`	`data: [{ id, full_name, mobile, role }]`
POST	`/organization/users`	`{ full_name, mobile (09xxxxxxxxx), role? }`
DELETE	`/organization/users/{id}`	`success:true`

نحوه‌ی ورود این کاربران و سطح دسترسی‌شان تصمیم بک‌اند است (مثلاً ورود با OTP روی همان شماره و ثبت سفارش به نام سازمان). اپ فعلاً فقط مدیریت فهرست را دارد.

۳-۵. بروزرسانی اپلیکیشن

`GET /app/version?platform=android|ios|web&current_version=2.74.3`

```
{ "success": true, "data": {
  "latest_version": "2.75.0",
  "min_supported_version": "2.70.0",
  "update_available": true,
  "force": false,
  "update_url": "https://..."
}}
```

`force:true` یعنی دکمه‌ی «بعداً» نمایش داده نشود. این درخواست بی‌صداست و شکستش به کاربر پیغام نمی‌دهد.

خروج از حساب، تغییر رمز عبور و حذف حساب در همین صفحه به endpointهای بخش ۷ وصل‌اند.

---

۴. عیوب سرویس / محصول (بند ۵)

اپ حالا شماره سفارش را هم از لیست و هم با **تایپ مستقیم** می‌گیرد و همه‌ی فیلدها جز «توضیحات» از خود سفارش پر می‌شوند. کارهای بک‌اند:

1. `GET /orders/summary` برای هر سفارش `product_name` را برگرداند. اگر سفارش محصول مشخصی ندارد، `category_title` را بفرستد. قبلاً وقتی `product_name` خالی بود، فیلد قفلِ «نام محصول/خدمت» خالی می‌ماند و ثبت گزارش ممکن نبود. اپ حالا در این حالت فیلد را قابل ویرایش می‌کند، ولی مقدار درست باید از سرور بیاید.
2. گزارش‌های ثبت‌شده از `POST` همان endpoint فعلی گزارش خرابی (`faultReportAPI.create`) در **پنل ادمین** با همه‌ی فیلدها نمایش داده شوند: `order_id`، `product_name`، `ordered_at`، `delivered_at`، `technician_code`، `paid_price`، `description`.
3. عنوان این بخش در پنل ادمین هم «**عیوب سرویس / محصول**» باشد، نه «خرابی خدمات».

---

۵. اطلاعات تکنسین و حذف شماره پس از پایان سفارش (بند ۶)

کارت تکنسین در اپ حالا همیشه چهار دکمه دارد: تماس، پیام، ارسال به دوستان و QR. «تماس» و «پیام» فقط تا وقتی سفارش جاری است (`status` 0 یا 1) فعال‌اند. **کار بک‌اند (الزامی، امنیتی):**

- در `GET /orders/{id}`، لیست سفارش‌ها و هر پاسخ دیگری که `technician` دارد: وقتی `status` سفارش **۲ (انجام‌شده) یا ۳ (لغوشده)** است، `technician.phone` را **اصلاً نفرستید** (یا `null`). حذف واقعی از سوابق کاربر سمت سرور است و پنهان کردن در اپ به‌تنهایی کافی نیست.
- برای نمایش کارت لازم است: `technician.name`، `technician_type` (مثلاً «تکنسین جامع میدانی»)، `referral_code` (کد تکنسین)، `created_at` (شروع فعالیت)، `profile_photo_path`.

---

۶. روش و کانال پرداخت (بند ۷)

اپ آماده است این سه فیلد را روی رسید، جزئیات سفارش و فهرست تراکنش‌ها نشان دهد. آن‌ها را به `GET /orders/{id}`، لیست سفارش‌ها و `GET /wallet/transactions` (و هر لیست تراکنش دیگر) اضافه کنید:

فیلد	مقادیر مجاز
`payment_method`	`cash` (نقدی)، `card_to_card` (کارت به کارت)، `sheba` (شبا)، `bank_transfer` (پرداخت درون‌بانکی)، `in_app` (پرداخت درون برنامه لوپ، شامل درگاه و کیف پول)، `unpaid` (پرداخت نشده)، `remaining` (مانده)
`payment_channel`	`app`، `site`، `in_person` (حضوری)

`remaining_amount`	عدد (تومان). فقط وقتی بخشی از مبلغ مانده است.

تا وقتی این فیلدها نیایند، اپ رفتار فعلی را نگه می‌دارد («پرداخت آنلاین» / «در انتظار پرداخت»). پرداخت‌های حضوری و سایت هم باید با همین سه فیلد ثبت شوند تا در اپ درست دیده شوند.

---

۷. امنیت حساب (سند «فیلد امنیت حساب»)

همه‌ی مسیرها زیر `/account` هستند و برای **هر دو نوع حساب** با توکن خودشان کار می‌کنند.

۷-۰. خلاصه: `GET /account/security`

```
{ "success": true, "data": {
  "two_factor": { "enabled": true, "method": "sms", "verified_mobile": "09120000000" },
  "mobile": { "number": "09120000000", "verified": true },
  "active_devices_count": 3,
  "unread_alerts_count": 2,
  "sessions_supported": true
}}
```

`sessions_supported:false` یعنی بک‌اند Session/Token را جدا از دستگاه‌ها مدیریت نمی‌کند. در این حالت اپ ردیف «مدیریت نشست‌ها» را حذف می‌کند (طبق خود سند).

۷-۱. تأیید دومرحله‌ای

متد	مسیر	بدنه	پاسخ `data`
POST	`/account/security/two-factor/send-code`	`{ purpose: "enable"|"disable"|"recovery_codes", method: "sms"|"app" }`	برای `enable` + `app`: `{ secret, otpauth_url }`. در بقیه‌ی حالت‌ها کد پیامک می‌شود: `{ expires_in, resend_in }`
POST	`/account/security/two-factor/enable`	`{ method, code }`	`{ recovery_codes: ["XXXX-XXXX", ...] }` (پیشنهاد: ۸ کد یک‌بارمصرف)
POST	`/account/security/two-factor/disable`	`{ code }`	—
POST	`/account/security/two-factor/recovery-codes`	`{ code }`	`{ recovery_codes: [...] }` (کدهای قبلی باطل می‌شوند)

> **ورود با دومرحله‌ای:** وقتی 2FA فعال است، ورود دو مرحله دارد. قرارداد کامل و نهایی در **بخش ۱۴** است و صفحه‌ی وارد کردن کد هنگام ورود در اپ پیاده شده است.

۷-۲. دستگاه‌های واردشده

ثبت دستگاه. اپ بعد از هر ورود این را بی‌صدا صدا می‌زند:

`POST /account/devices/register`

```
{ "device_id": "uuid", "platform": "android", "device_type": "phone|tablet|browser",
  "device_model": "Samsung Galaxy A25", "os_name": "Android", "os_version": "14",
"app_version": "2.74.3" }
```

سرور این دستگاه را به **توکن جاری** گره بزند تا بتواند `is_current` و «خروج از این دستگاه» را درست انجام دهد. IP و زمان آخرین فعالیت را خود سرور از درخواست‌ها ثبت کند.

متد	مسیر	پاسخ / رفتار
GET	`/account/devices`	`data: [{ id, device_id, device_type, device_model, os_name, os_version, app_version, last_ip, approx_location, last_activity_at, is_current }]`
DELETE	`/account/devices/{id}`	توکن(های) آن دستگاه باطل شود. دستگاه فعلی را با این مسیر حذف نکنید (اپ دکمه‌اش را نشان نمی‌دهد).

`approx_location` اختیاری است (مثلاً «تهران» از روی IP).

۷-۳. خروج از سایر دستگاه‌ها

`POST /account/devices/logout-others` با بدنه‌ی `{ current_device_id }`. همه‌ی توکن‌ها **به‌جز توکن همین درخواست** باطل شوند. ⚠️ `/auth/logout-all` و `/organization/logout-all` فعلی به این کار نمی‌آیند، چون کاربر را از دستگاه فعلی هم بیرون می‌کنند.

۷-۴. فعالیت‌های اخیر حساب

`GET /account/activities?page=1` → `data: [{ id, type, title, created_at, device, os, ip, result: "success"|"failed", approx_location }]` (جدیدترین اول، صفحه‌بندی ۲۰تایی).

`type`های قابل‌شناسایی در اپ: `login_success`، `login_failed`، `two_factor_enabled`، `two_factor_disabled`، `mobile_changed`، `device_logout`، `logout_other_devices`، `password_changed`، `security_info_changed`، `session_ended`، `deletion_requested`. برای `type` ناشناخته، اپ `title` را نمایش می‌دهد.

سرور باید این رویدادها را **خودش** در همان لحظه ثبت کند (ورود، تغییر رمز، ...).

۷-۵. مدیریت نشست‌ها (اختیاری)

متد	مسیر	پاسخ

GET	`/account/sessions`	`data: [{ id, device, os, app_version, ip, created_at, last_activity_at, expires_at, status: "active"|"expired", is_current }]`
DELETE	`/account/sessions/{id}`	توکن آن نشست باطل شود

اگر پیاده نمی‌کنید، در `/account/security` مقدار `sessions_supported:false` بفرستید.

۷-۶. تأیید و تغییر شماره موبایل

متد	مسیر	بدنه	پاسخ `data`
POST	`/account/mobile/send-code`	`{}` برای تأیید شماره‌ی فعلی، یا `{ mobile }` برای تغییر شماره	`{ expires_in: 120, resend_in: 60, remaining_attempts: 4 }`
POST	`/account/mobile/verify`	`{ code }` یا `{ code, mobile }`	—

محدودیت تعداد درخواست را سرور اعمال کند (پیشنهاد: ۵ بار در ساعت؛ وقتی تمام شد 429 با `message`). تغییر شماره یک رویداد فعالیت و یک هشدار امنیتی ثبت کند. شماره‌ی جدید نباید متعلق به حساب دیگری باشد (422).

۷-۷. هشدارهای امنیتی

متد	مسیر	توضیح
GET	`/account/security-alerts`	`data: [{ id, type, title, message, created_at, device, ip, is_read, severity: "low"|"medium"|"high"|"critical", suggested_action }]`
POST	`/account/security-alerts/{id}/read`	خوانده شد
POST	`/account/security-alerts/read-all`	همه خوانده شد
GET / PUT	`/account/security-alerts/settings`	`{ notifications_enabled: true/false }`

`type`ها: `new_device_login`، `multiple_failed_logins`، `password_changed`، `mobile_changed`، `two_factor_changed`، `unusual_activity`. اگر کاربر اعلان‌ها را خاموش کند، هشدارهای `critical` باز هم باید ارسال شوند (طبق سند). ارسال push برای هشدارها از همان مسیر FCM فعلی (`FIREBASE_NOTIFICATIONS.md`) با `data.type: "security_alert"` پیشنهاد می‌شود.

۷-۸. حذف حساب کاربری

متد	مسیر	بدنه	پاسخ `data`

GET	`/account/deletion-request`	—	درخواست جاری یا `null` : `{ status, requested_at, scheduled_at, executed_at, reason }`
POST	`/account/deletion-request/send-code`	—	کد پیامکی به شماره‌ی حساب
POST	`/account/deletion-request`	`{ code, reason? }`	همان شیء درخواست
POST	`/account/deletion-request/cancel`	—	—

`status` : `pending` (در انتظار)، `approved` (تأیید شده)، `done` (انجام شده)، `canceled` (لغو شده)، `rejected` .

- **حساب سازمانی / شرکتی:** درخواست فقط ثبت می‌شود (`pending`) و **پس از تأیید پنل ادمین** اجرا می‌شود. پنل ادمین برای این درخواست‌ها صف تأیید/رد لازم دارد.
- **حساب عادی:** می‌توانید مستقیم `approved` با `scheduled_at` (مثلاً ۱۴ روز بعد برای امکان انصراف) برگردانید.
- حذف حساب **به معنی حذف فوری سوابق سفارش و خدمات نیست** (بند ۱۳ حریم خصوصی). سوابق مالی و خدماتی طبق الزامات قانونی نگهداری یا ناشناس‌سازی شوند.

---

۸. حریم خصوصی ✅ بدون نیاز به بک‌اند

متن کامل سیاست حریم خصوصی (نسخه 1.0، 1405/07/20، سند LIT-UP-001) داخل اپ است. اگر روی سایت هم نمایش داده می‌شود، همین نسخه را منتشر کنید.

---

۹. تامین کالا: استعلام قیمت، پیش‌پرداخت ۶۰٪ و باقی‌مانده (بند ۱۱)

روند کامل (فقط برای کاربر سازمانی / شرکتی): کاربر سفارشی با اقلام «تامین تجهیزات / کالا» ثبت می‌کند (پیش‌رسید) ← پنل برای اقلام قیمت اعلام می‌کند و اعتبار استعلام **تا پایان ساعات کاری همان روز** است ← کاربر قیمت‌ها را تأیید می‌کند ← **پیش‌پرداخت ۶۰٪** جمع کل (این درصد پیش‌فرض است و باید در پنل قابل تغییر باشد) ← لوپ کالا را آماده می‌کند ← **پرداخت باقی‌مانده** ← ارسال (لوپ / کاربر / پیک، بخش ۱۰).

۹-۱. فیلدهای تازه در `POST /orders/submit`

هر دو مسیر سازمانی (سیستماتیک و جامع) این فیلدها را **علاوه بر** فیلدهای فعلی می‌فرستند (اگر خالی باشند اصلاً فرستاده نمی‌شوند):

فیلد	نوع	توضیح
`procurement_items`	آرایه	اقلام تامین کالا: `[{ "item_id": "laptop", "title": "لپ تاپ", "new_count": 2, "used_count": 1, "description": "..." }]` . `title` همیشه فارسی است.

`delivery_mode`	آرایه‌ی رشته	فقط «انتخاب جامع»: هر کدام از `once_short` (کوتاه مدت / یکبار)، `monthly_short`، `yearly_long`، `project`.
`technician_gender`	رشته	فعلاً فقط `male`.

کارهای بک‌اند:

1. این سه فیلد را ذخیره کنید. تا الان اقلام تامین کالا فقط داخل متن `description` می‌آمدند و پنل نمی‌توانست برایشان قیمت بدهد.
2. **«انتخاب جامع» حالا ممکن است فقط تامین کالا داشته باشد** و هیچ ردیف خدمات نرم‌افزاری/سخت‌افزاری نداشته باشد. چنین سفارشی را رد نکنید. اپ برای آن فقط این مراحل را اجباری می‌کند: تامین تجهیزات، نحوه ارائه «کوتاه مدت / یکبار»، بازه زمانی، آدرس، اطلاعات اپراتور و انتخاب تکنسین.
3. اگر `procurement_items` خالی نبود و حساب سازمانی/شرکتی است، برای سفارش یک «استعلام تامین کالا» با وضعیت `awaiting_quote` بسازید و در پنل ادمین صف «استعلام تامین کالا» نمایش دهید.

۹-۲. پنل ادمین

- برای هر قلم: وضعیت (نو / کارکرده)، تعداد، **قیمت واحد** و توضیح. جمع کل خودکار.
- با «اعلام قیمت»، `valid_until` = **پایان ساعات کاری همان روز** (ساعت پایان کار در تنظیمات پنل قابل تغییر باشد، مثلاً ۱۷:۰۰ به وقت تهران) و وضعیت `quoted`.
- **درصد پیش‌پرداخت:** پیش‌فرض سراسری `60`، قابل تغییر در تنظیمات پنل (و ترجیحاً قابل تغییر برای هر سفارش).
- دکمه‌های «کالا آماده شد» (`ready`)، «ارسال شد» (`shipped`).

۹-۳. فیلد تازه در پاسخ جزئیات سفارش (`POST /orders/detail`) و لیست سفارش‌ها

```
"procurement": {
  "status": "quoted",
  "items": [
    { "id": 11, "item_id": "laptop", "title": "لپ تاپ", "condition": "new",
      "quantity": 2, "unit_price": 45000000, "total_price": 90000000, "description": null }
  ],
  "total_amount": 90000000,
  "quoted_at": "2026-10-12T10:20:00+03:30",
  "valid_until": "2026-10-12T17:00:00+03:30",
  "note": "توضیح پنل (اختیاری)",
  "payment": {
    "prepayment_percent": 60,
    "prepayment_amount": 54000000,
    "prepayment_paid": false,
    "prepayment_paid_at": null,
    "remaining_amount": 36000000,
    "remaining_paid": false,
    "remaining_paid_at": null
  }
}
```

- برای سفارشی که تامین کالا ندارد، `procurement` را نفرستید (یا `null`). اپ بخش را فقط وقتی این فیلد هست نشان می‌دهد.

- `condition` : `new` یا `used` . `prepayment_paid` / `remaining_paid` : بولین (۰/۱ هم پذیرفته می‌شود).
- اگر `prepayment_amount` یا `remaining_amount` نیاید، اپ از `total_amount × درصد` حساب می‌کند؛ ولی **مبلغ قطعی را سرور تعیین می‌کند** و باید همان را بفرستد.

وضعیت‌ها (`status`):

مقدار	معنی	اقدام کاربر در اپ
`awaiting_quote`	منتظر اعلام قیمت پنل	—
`quoted`	قیمت اعلام شده	تأیید یا رد
`accepted`	کاربر تأیید کرده	پرداخت پیش‌پرداخت
`rejected`	کاربر رد کرده	—
`expired`	از `valid_until` گذشته	«درخواست استعلام مجدد»
`preparing`	پیش‌پرداخت انجام شده، لوپ در حال آماده‌سازی	—
`ready`	کالا آماده است	پرداخت باقی‌مانده
`shipped`	ارسال شد	—
`delivered`	تحویل شد	—

اگر وضعیت `quoted` بماند ولی زمان از `valid_until` گذشته باشد، اپ آن را «منقضی» نشان می‌دهد. سرور هم باید پس از این زمان تأیید را رد کند.

۹-۴. اقدامات کاربر

متد	مسیر	بدنه	رفتار
POST	`/orders/{id}/procurement/accept`	`{}`	فقط در `quoted` و پیش از `valid_until` ؛ وگرنه 422 با `error_code:` `"QUOTE_EXPIRED"`. وضعیت ← `accepted` .
POST	`/orders/{id}/procurement/reject`	`{ reason? }`	وضعیت ← `rejected` .
POST	`/orders/{id}/procurement/requote`	`{}`	فقط در `expired` . وضعیت ← `awaiting_quote` و دوباره در صف پنل.
POST	`/orders/{id}/procurement/pay`	`{ stage, method, linking_url? }`	پرداخت یک مرحله؛ پایین را ببینید.

پرداخت مرحله‌ای:

- `stage` : `prepayment` (فقط در `accepted`) یا `remaining` (فقط در `ready`). در غیر این صورت 422.

- `method: "wallet"` : مبلغ همان مرحله از کیف پول کم شود. پاسخ: `{ "remaining_balance": 1200000 }` . موجودی کم ← 422 با `error_code: "INSUFFICIENT_BALANCE"` و `message` فارسی.
- `method: "gateway"` : پاسخ `{ "payment_url": "..." }` . بازگشت از درگاه دقیقاً مثل `/orders/gateway-payment` فعلی به `linking_url` با `status=OK|NOK` .
- بعد از پیش‌پرداخت ← `preparing` . بعد از پرداخت باقی‌مانده ← `payment_status` خود سفارش `1` شود (تا مراحل «وضعیت ارسال» و «دریافت محصول / سفارش» در اپ باز شوند).
- هر دو پرداخت در فهرست تراکنش‌ها با `payment_method` / `payment_channel` (بخش ۶) ثبت شوند.

۹-۵. پیش‌پرداخت «اعزام به لوپ» برای کاربر عادی

همین قانون برای محصولی که برای تعمیر به لوپ اعزام شده هم برقرار است. اپ از قبل فیلدهای فعلی `prepayment` (درصد)، `loop_cost_estimate` و `prepayment_payment_status` را نمایش می‌دهد و درصد را کنار مبلغ می‌نویسد. کارهای بک‌اند:

1. `prepayment` برای هر اعزام به لوپ **به‌طور پیش‌فرض** `60` باشد (قابل تغییر در پنل). الان اگر خالی بیاید، کاربر بدون پرداخت تأیید می‌کند.
2. پنل تا وقتی `prepayment_payment_status = 1` نشده، اجازه‌ی شروع تعمیر ندهد.
3. باقی‌مانده بعد از تعمیر از همان مرحله‌ی «پرداخت» فعلی گرفته می‌شود: مبلغ قابل پرداخت = کل - پیش‌پرداخت. ارسال به کاربر فقط بعد از `payment_status = 1` .

---

۱۰. مشخصات تحویل در رسیدها و سفارش (بند ۱۵)

برای سفارش‌هایی که کالا / محصول **از لوپ به کاربر** برمی‌گردد (اعزام به لوپ و تامین کالا)، کاربر در «جزئیات سفارش» مشخص می‌کند چه کسی تحویل می‌گیرد و از چه راهی ارسال شود. رسید هم «تحویل گیرنده»، «تاریخ و ساعت تحویل» و «وضعیت تحویل» را از همین داده می‌خواند.

۱۰-۱. فیلد تازه در پاسخ جزئیات سفارش

```
"delivery": {
  "receiver_type": "representative",
  "receiver_name": "علی رضایی",
  "receiver_mobile": "09120000000",
  "receiver_national_id": "0012345678",
  "method": "courier",
  "status": "shipped",
  "delivered_at": null
}
```

فیلد	مقادیر
`receiver_type`	`self` (خود کاربر) یا `representative` (نماینده / شخص دیگر)
`receiver_name` ، `receiver_mobile`	برای `self` سرور از خود حساب پر کند.

`receiver_national_id`	اختیاری، ۱۰ رقم.
`method`	`loop_technician` (توسط تکنسین لوپ)، `user` (خود کاربر / تحویل حضوری)، `courier` (پیک حمل و نقل)
`status`	`pending` ، `ready` ، `shipped` ، `delivered`
`delivered_at`	تاریخ و ساعت تحویل (ISO).

۱۰-۲. ثبت توسط کاربر: `PUT /orders/{id}/delivery`

```
{ "receiver_type": "representative", "method": "courier",
  "receiver_name": "علی رضایی", "receiver_mobile": "09120000000", "receiver_national_id": null
}
```

- برای `self` فقط `receiver_type` و `method` می‌آید.
- اعتبارسنجی: موبایل `09xxxxxxxxx` ، کد ملی ۱۰ رقم (اختیاری). خطا ← 422 با `message` فارسی.
- بعد از `shipped` یا `delivered` ویرایش ممکن نیست ← 422.
- پنل باید این مشخصات را ببیند و بتواند روش ارسال را اصلاح کند.

۱۰-۳. تاریخ و ساعت تحویل

«تاریخ تحویل: موقع دریافت و ثبت از سوی کاربر تکمیل می‌شود». وقتی کاربر در اپ «دریافت محصول / سفارش» را ثبت می‌کند (`POST /orders/{id}/final-description` فعلی)، سرور `delivery.delivered_at = now()` و `delivery.status = "delivered"` را ثبت کند. اپ برای این کار درخواست جداگانه‌ای نمی‌فرستد.

---

۱۱. «ویرایش» و «درخواست ویرایش» در حساب سازمانی / شرکتی (بند ۱۰)

پروفایل سازمانی حالا دو دکمه دارد: **«ویرایش»** و **«درخواست ویرایش»**.

گروه	فیلدها (کلید API)	چه کسی تغییر می‌دهد
آزاد	`profile_image` ، `agent_name` (نام نماینده‌ی مدیرعامل)، `agent_phone` (شماره‌ی نماینده)، `history` (سابقه‌ی فعالیت نماینده)، `organization_email` ، `organization_phone` (تلفن ثابت)، `region` (منطقه)، `city` ، `postal_code` ، `organization_address`	خود کاربر، **فوری و بدون بررسی ادمین**
قفل	`organization_name` ، `manager_mobile` (موبایل ثبت‌شده‌ی حساب)، `manager_national_code` ، `manager_full_name` (نام مدیرعامل)، و همچنین `business_name` ، `melicode` ، `registration_number` ، `economic_code` ، `manager_birthdate`	فقط پس از تأیید «درخواست ویرایش» در پنل، **یک بار**؛ بعد از ذخیره دوباره قفل

پنج فیلد اول گروه قفل را سند مشتری نام برده است. پنج فیلد بعدی (اطلاعات هویتی و ثبتی سازمان) در سند تکلیفشان مشخص نشده و به‌طور پیش‌فرض قفل در نظر گرفته شده‌اند. اگر کسب‌وکار نظر دیگری دارد، همین جدول را تغییر دهید

> و به تیم اپ اطلاع دهید.

۱۱-۱. ثبت درخواست: `POST /organization/edit-requests` (multipart)

فیلد	الزامی	توضیح
`letter`	✅	نامه‌ی رسمی با **مهر و امضا**؛ PDF یا تصویر، حداکثر ۱۰ مگابایت.
`description`	✅	توضیح تغییرات درخواستی («درخواست تغییر اطلاعات حساب کاربری»).
`fields[]`	—	(اختیاری) کلید فیلدهای قفلی که کاربر می‌خواهد عوض کند.

- پاسخ: همان شیء درخواست. اگر درخواست در انتظار دیگری هست ← 409 با `message`.

۱۱-۲. فیلدهای تازه در `GET /organization/profile`

```
"edit_request": {
  "id": 7, "status": "approved", "description": "...", "letter_url": "https://...",
  "fields": ["organization_name"], "admin_note": null,
  "created_at": "...", "reviewed_at": "..."
},
"locked_fields_unlocked": true,
"unlocked_fields": ["organization_name", "manager_full_name"]
```

- `status`: `pending` (در انتظار بررسی)، `approved` (تأیید؛ فیلدها باز)، `rejected` ، `used` (ویرایش انجام شد و دوباره قفل شد).
- `locked_fields_unlocked`: فقط وقتی `true` باشد اپ فیلدهای قفل را باز می‌کند (پیش‌فرض اپ همیشه قفل است).
- `unlocked_fields` اختیاری است: اگر پنل فقط بعضی فیلدها را باز کرد، همان‌ها را بفرستید؛ نبودنش یعنی همه‌ی فیلدهای قفل.
- `letter_url` باید برای کاربر قابل باز شدن باشد.

۱۱-۳. تغییر رفتار `POST /organization/update-profile`

1. **به‌روزرسانی جزئی:** اپ فقط فیلدهای مجاز را می‌فرستد. فیلدی که نیامده نباید خالی شود.
2. فیلدهای **آزاد** فوراً اعمال شوند (دیگر لازم نیست وارد `edited_organization` و صف تأیید ادمین شوند).
3. فیلدهای **قفل** فقط وقتی پذیرفته شوند که `locked_fields_unlocked = true` است؛ وگرنه 403 با `error_code: "FIELDS_LOCKED"`. پس از ذخیره‌ی موفق: `locked_fields_unlocked = false` و `edit_request.status = "used"`.
4. دو فیلد تازه در بدنه: `manager_national_code` و `manager_mobile` (فقط در حالت باز). تغییر `manager_mobile` یعنی تغییر شماره‌ی ورود. توصیه می‌شود شماره‌ی جدید با OTP تأیید شود (بخش ۷-۶).
5. پنل ادمین: صف «درخواست‌های ویرایش» با نمایش نامه، تأیید (با امکان انتخاب فیلدها) یا رد با توضیح (`admin_note`).

---

۱۲. عکس پروفایل: برش گرد، آواتار، حذف (بند ۱۲)

سمت اپ کامل است: برش **دایره‌ای**، دوربین، گالری، آواتارهای آماده (آقا، خانم، بچه‌ها، لوگوی لوپ، یوزپلنگ و برای سازمان‌ها نمای چند ساختمان شرکت) و نمایش تمام‌صفحه. خروجی همیشه یک تصویر مربع ۵۱۲×۵۱۲ (JPEG یا PNG) است. آپلود از همان مسیر فعلی است:

- کاربر عادی: `POST /profile` (multipart با `_method=PUT`)، فیلد `profile_photo_path`.
- سازمانی: `POST /organization/update-profile` (multipart)، فیلد `profile_image`.

تنها کار بک‌اند: حذف عکس.

حساب	درخواست	رفتار
عادی	`PUT /profile` با `{ "remove_profile_photo": 1 }` (کنار بقیه‌ی فیلدها)	`profile_photo_path = null` و حذف فایل
سازمانی	`POST /organization/update-profile` با `{ "remove_profile_image": 1 }`	`profile_image = null` و حذف فایل (فیلد آزاد است؛ تأیید ادمین لازم نیست)

حداکثر حجم پیشنهادی ۵ مگابایت؛ فرمت‌های `jpeg`، `png`، `webp`.

---

۱۳. کیف پول مأمور خرید (بند ۹)

مأمور خرید شرکتی / سازمانی صاحب یک کد معرف (`LOOP-XXXXXX`) است. از هر سفارشی که با کد او **ثبت و تسویه‌ی کامل** شود، درصدی پورسانت می‌گیرد. درصد هر کد جداگانه در پنل تعیین می‌شود (بخش ۲). پورسانت در «کیف پول مأمور خرید» جمع می‌شود و مأمور می‌تواند:

- **برداشت به حساب (شبا):** همان لحظه، یا وقتی چند پورسانت جمع شد.
- **تهاتر:** به‌جای واریز، مبلغ به کیف پول لوپ همان کاربر منتقل شود تا با آن کالا / محصول از لوپ بخرد.

اپ ورودی این کیف پول را در صفحه‌ی «کیف پول» فقط وقتی نشان می‌دهد که `summary` موفق باشد و `is_agent: true` بدهد. برای بقیه‌ی کاربران چیزی دیده نمی‌شود.

۱۳-۱. پنل ادمین

- علامت‌گذاری کاربر به‌عنوان «مأمور خرید»، تخصیص کد معرف و `commission_percent` برای همان کد.
- هر سفارشِ دارای `referral_code` مأمور: هنگام ثبت، یک پورسانت با وضعیت `pending` ثبت شود. وقتی سفارش تسویه‌ی کامل شد (`payment_status = 1` و انجام‌شده) ← `available`. سفارش لغو شد ← `canceled`.
- صف «درخواست‌های برداشت»: واریز و ثبت `tracking_code` ← `paid`، یا رد با `admin_note` ← `rejected` (مبلغ به موجودی قابل برداشت برگردد).
- `min_withdraw_amount` (حداقل برداشت به شبا) در تنظیمات.

۱۳-۲. endpointها

متد	مسیر	پاسخ `data`
GET	`/referral-agent/summary`	`{ is_agent, referral_code, commission_percent, available_balance, pending_balance, total_earned, total_withdrawn, total_offset, min_withdraw_amount, sheba_number }`
GET	`/referral-agent/commissions?page=1`	`[{ id, order_id, order_amount, commission_percent, commission_amount, status, created_at, settled_at }]`
GET	`/referral-agent/withdrawals`	`[{ id, amount, method, status, sheba_number, tracking_code, admin_note, created_at, processed_at }]`
POST	`/referral-agent/withdrawals`	بدنه: `{ amount, method: "sheba" | "offset", sheba_number? }` ← همان شیء برداشت

- کاربر غیرمأمور: `summary` با `{ "is_agent": false }` یا 403 جواب دهد.
- وضعیت پورسانت: `pending`، `available`، `withdrawn`، `offset`، `canceled`.
- وضعیت برداشت: `pending`، `approved`، `paid`، `done`، `rejected`.
- `sheba_number` با فرمت `IR` + ۲۴ رقم (اپ checksum را هم چک می‌کند). مقدار پیش‌فرض را از شبای پروفایل کاربر در `summary` بفرستید.
- `method: "offset"` **(تهاتر):** همان لحظه از `available_balance` کم و به کیف پول لوپ اضافه شود؛ وضعیت `done`؛ یک تراکنش کیف پول با نوع تازه (پیشنهاد: `type = 4`، «تهاتر پورسانت») ثبت شود.
- `method: "sheba"`: درخواست `pending` ثبت شود و مبلغ از `available_balance` رزرو شود.
- خطاها (422 با `message` فارسی): مبلغ بیشتر از موجودی، کمتر از حداقل، شبای نامعتبر.

---

۱۴. مرحله‌ی دوم ورود با تأیید دومرحله‌ای (تکمیل ۷-۱)

صفحه‌ی وارد کردن کد هنگام ورود **حالا در اپ پیاده شده است**، هم برای کاربر عادی و هم برای سازمانی.

1. وقتی 2FA فعال است، `POST /auth/login` و `POST /organization/login` به‌جای توکن برگردانند:

```
{ "success": true, "requires_two_factor": true, "two_factor_token": "...", "method": "sms"
}
```

`method`: `sms` یا `app`. برای `sms` همان لحظه کد پیامک شود. `two_factor_token` حداکثر ۵ دقیقه معتبر باشد.

2. تأیید کد:

حساب	مسیر	بدنه
عادی	`POST /auth/two-factor/verify`	`{ two_factor_token, code }`

سازمانی	`POST /organization/two-factor/verify`	`{ two_factor_token, code }`

پاسخ موفق **دقیقاً همان شکل پاسخ موفق ورود همان حساب** را داشته باشد: کاربر عادی `{ success: true, data: { token, user } }` و سازمانی `{ status: "success", data: { token, user, organization } }`. `code` می‌تواند کد بازیابی اضطراری (`XXXX-XXXX`) هم باشد؛ کد بازیابی یک‌بارمصرف است.

3. ارسال مجدد: `POST /auth/two-factor/resend` و `POST /organization/two-factor/resend` با `{ two_factor_token }`. اپ بین دو ارسال ۶۰ ثانیه صبر می‌کند.
4. **کد اشتباه را با 422 جواب دهید، نه 401.** پاسخ 401 در اپ پیغام «نشست شما منقضی شده» را باز می‌کند. تلاش زیاد ← 429.
5. ورود موفق و ناموفق در «فعالیت‌های اخیر» (بخش ۷-۴) ثبت شود.

چک‌لیست خلاصه برای تیم بک‌اند

#	کار	بخش	اولویت
1	حذف `technician.phone` از پاسخ‌ها پس از پایان یا لغو سفارش	۵	**بالا (امنیتی)**
2	ذخیره‌ی `procurement_items` / `delivery_mode` / `technician_gender` + پذیرش سفارش جامعِ فقط-تامین-کالا	۹-۱	**بالا**
3	استعلام تامین کالا در پنل + `procurement` در جزئیات سفارش + accept / reject / requote / pay	۹-۲ تا ۹-۴	**بالا**
4	پیش‌فرض ۶۰٪ (قابل تغییر) برای پیش‌پرداخت اعزام به لوپ + منع شروع تعمیر پیش از پرداخت	۵-۹	**بالا**
5	`product_name` / `category_title` در `/orders/summary` و نمایش گزارش «عیوب سرویس / محصول» در پنل	۴	بالا
6	`payment_method` / `payment_channel` / `remaining_amount` روی سفارش و تراکنش	۶	بالا
7	`melicode`، `registration_number`، `economic_code`، `verification_status` در پروفایل سازمان	۳	بالا
8	`delivery` در جزئیات سفارش + `PUT /orders/{id}/delivery` + ثبت `delivered_at` هنگام «دریافت محصول»	۱۰	بالا
9	فیلدهای آزاد/قفل، `edit_request` و `POST /organization/edit-requests` + صف پنل	۱۱	بالا
10	حذف عکس پروفایل (`remove_profile_photo` / `remove_profile_image`)	۱۲	متوسط
11	کیف پول مأمور خرید: پورسانت، برداشت به شبا، تهاتر + صف پنل	۱۳	متوسط
12	ورود دومرحله‌ای: `requires_two_factor` + verify / resend برای هر دو حساب	۱۴ و ۱-۷	متوسط
13	`/account/security`، دستگاه‌ها (ثبت، فهرست، خروج، خروج از سایرین)	۷	متوسط

14	حذف حساب + صف تأیید ادمین برای حساب سازمانی	۷-۸	متوسط
15	تأیید/تغییر شماره موبایل	۷-۶	متوسط
16	فعالیت‌ها و هشدارهای امنیتی (ثبت رویدادها در سرور)	۷-۴، ۷-۷	متوسط
17	مدارک و کاربران مجاز سازمان	۳-۳، ۳-۴	پایین
18	`/app/version`	۳-۵	پایین
19	درصد جداگانه‌ی کد معرف در پنل (`discount_percent` / `commission_percent`)	۲	طبق نیاز کسب‌وکار
20	نشست‌ها (یا `sessions_supported:false`)	۷-۵	پایین